Informe Laboratorio 3

Sección 2

Darien Reyes
e-mail: darien.reyes@mail.udp.cl

Octubre de 2026

Índice

1. Descripción de actividades **2**

2. Desarrollo de actividades **2**
2.1. Identifica el algoritmo de hash utilizado al momento de registrarse en el sitio 2
2.2. Identifica el algoritmo de hash utilizado al momento de iniciar sesión 3
2.3. Genera el hash de la contraseña desde la consola del navegador 3
2.4. Intercepta el tráfico login con BurpSuite 3
2.5. Realiza el intento de login 4
2.6. Identifica las políticas de privacidad o seguridad 7
2.7. Demuestra 4 conclusiones sobre la seguridad 8

1. Descripción de actividades

Su objetivo será auditar la implementación de algoritmos hash aplicados a contraseñas en páginas web desde el lado del cliente, así como evaluar la efectividad de estas medidas contra ataques de tipo Pass the Hash (PtH). Para llevar a cabo esta auditoría, deberá registrarse en un sitio web y crear una cuenta, ingresando una contraseña específica para realizar las pruebas.

Al concluir la tarea, es importante que modifique su contraseña por una diferente para garantizar su seguridad.

Dado que la cantidad de sitios chilenos que utilizan hash es limitada, se permite realizar esta tarea en cualquier sitio web a nivel mundial. En este sentido, realice las siguientes actividades:

- Identificación del algoritmo de hash utilizado para las contraseñas al momento del registro en el sitio.
- Identificación del algoritmo de hash utilizado para las contraseñas al momento de iniciar sesión.
- Generación del hash de la contraseña desde la consola del navegador, partiendo de la contraseña en texto plano.
- Interceptación del tráfico de login utilizando BurpSuite desde su equipo.
- Realización de un intento de login, modificando una contraseña incorrecta por el hash obtenido en el punto anterior.
- Descripción de las políticas de privacidad o seguridad relacionadas con las contraseñas, incluyendo un enlace a las mismas.
- Cuatro conclusiones sobre la seguridad o vulnerabilidad de la implementación observada.

2. Desarrollo de actividades

2.1. Identifica el algoritmo de hash utilizado al momento de registrarse en el sitio

En el sitio auditado (LinuxQuestions.org), se inspeccionó el formulario utilizado durante la creación de una cuenta nueva para comprender cómo se administran y transmiten los datos ingresados por el usuario.

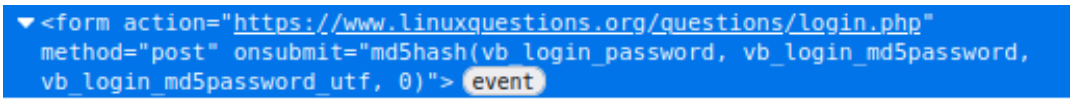


Figura 1: Formulario de registro del sitio web.

2.2. Identifica el algoritmo de hash utilizado al momento de iniciar sesión

Al momento de iniciar sesión, se observó que la plataforma emplea el algoritmo MD5. Se utiliza una función de JavaScript en el lado del cliente que procesa la contraseña en texto plano ingresada en el formulario y la convierte en un hash antes de despachar la solicitud HTTP hacia el servidor.

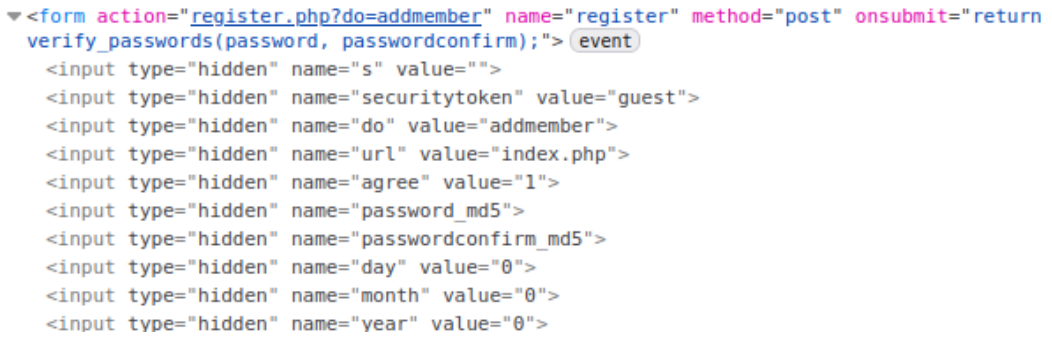


Figura 2: Evidencia del uso del algoritmo MD5 en el formulario de inicio de sesión.

2.3. Genera el hash de la contraseña desde la consola del navegador

Haciendo uso de la consola de desarrollador del navegador web, se invocó manualmente la función responsable de cifrar la contraseña. A partir del texto plano de prueba, se generó satisfactoriamente la cadena hexadecimal de 32 caracteres que será transportada por la red.



Figura 3: Generación del hash MD5 directamente desde la consola del navegador.

2.4. Intercepta el tráfico login con BurpSuite

Mediante el uso de la herramienta Burp Suite configurada como proxy, se capturó la petición `POST` originada al intentar iniciar sesión. Se verificó que la contraseña en texto plano

no se incluye en el cuerpo de la solicitud; en su lugar, la credencial viaja codificada dentro del parámetro `vb_login_md5password`.

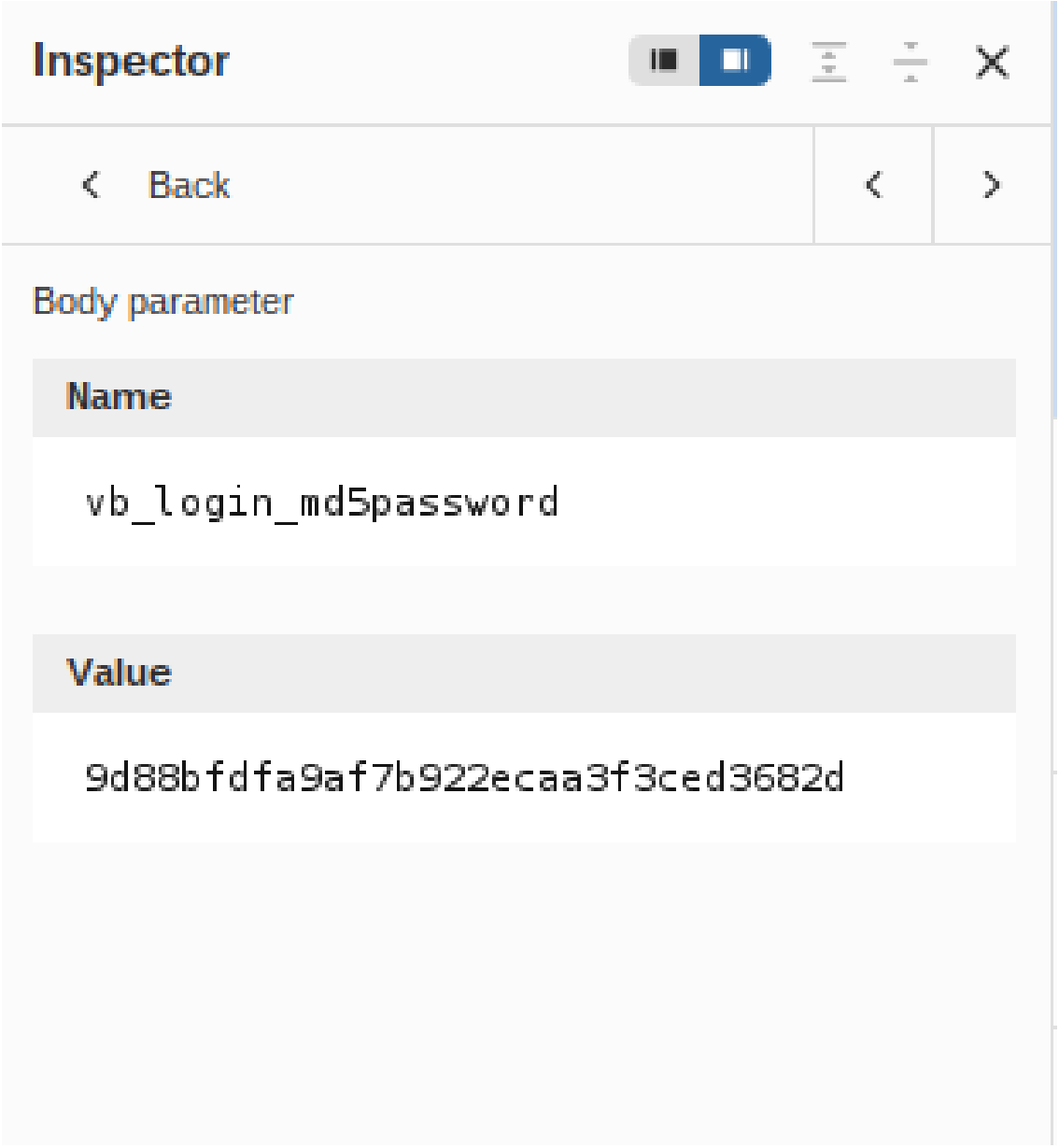


Figura 4: Tráfico de inicio de sesión interceptado mostrando el parámetro con el hash MD5.

2.5. Realiza el intento de login

Para corroborar si el sistema es vulnerable a la reutilización del hash (Pass the Hash), se procedió a enviar la petición capturada al módulo Repeater de Burp Suite para realizar pruebas de validación directa.

En primer lugar, se alteró la cadena del hash en el cuerpo de la petición simulando el envío de una contraseña incorrecta. Como respuesta, el servidor denegó la autenticación, omitiendo la asignación de las cookies de sesión.

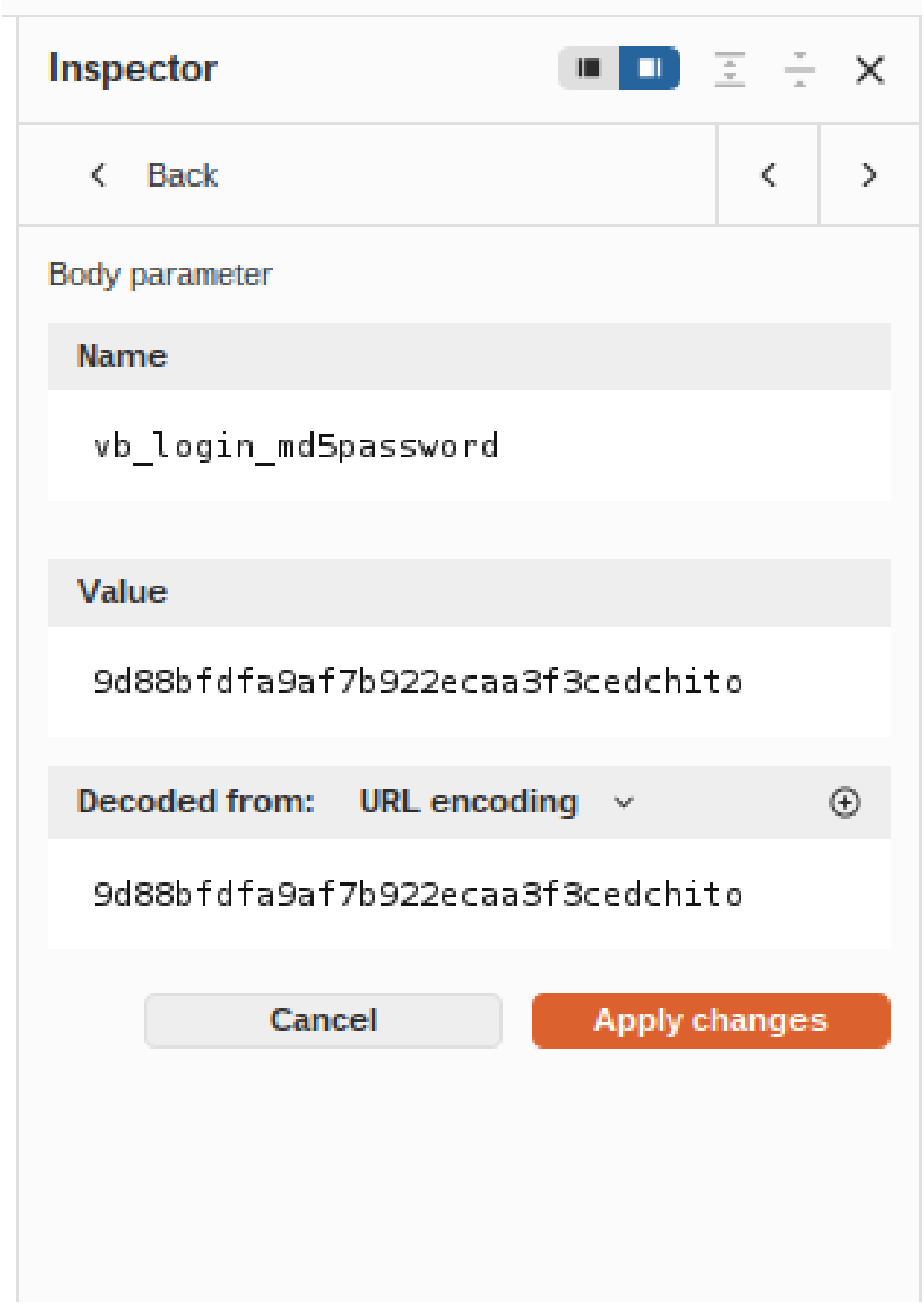


Figura 5: Modificación del hash en Burp Suite Repeater.

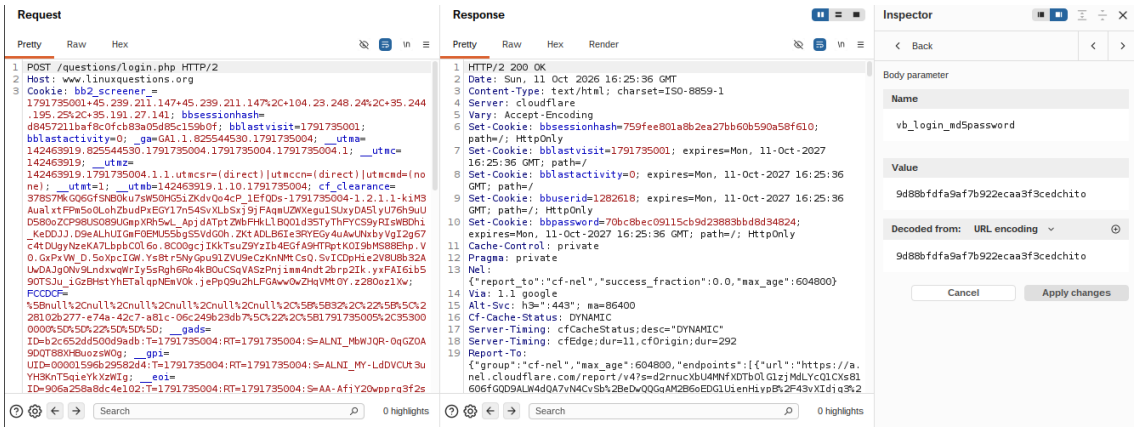


Figura 6: Respuesta del servidor rechazando la autenticación tras modificar el hash.

Posteriormente, se restauró el parámetro con el hash original y correcto sin incluir en ningún momento la contraseña en texto plano. La solicitud obtuvo un código de estado `HTTP/2 200 OK` y el servidor entregó todas las cookies correspondientes a un usuario validado (`bbuserid`, `bbsessionhash`, `bbpassword`), consolidando el acceso.

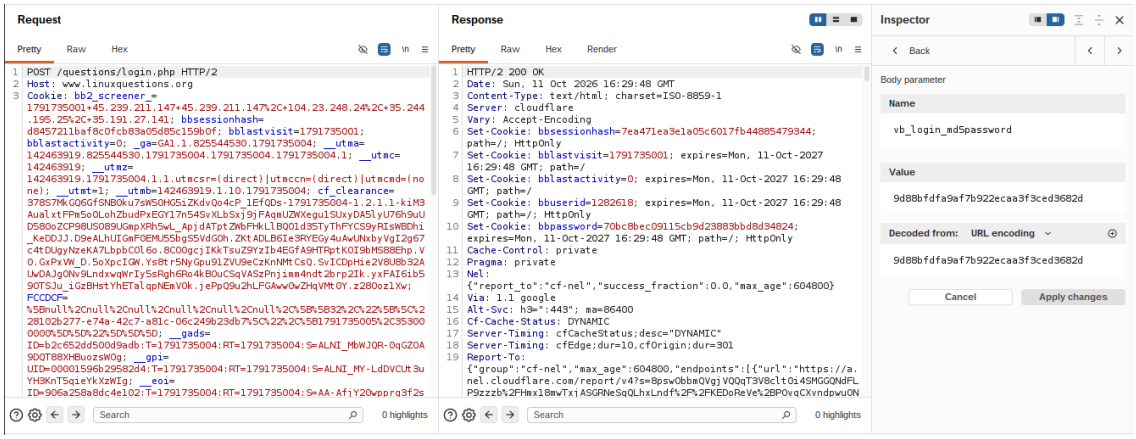


Figura 7: Respuesta exitosa del servidor entregando las cookies de sesión mediante el uso exclusivo del hash.

2.6. Identifica las políticas de privacidad o seguridad

LinuxQuestions.org documenta sus políticas de gestión y tratamiento de credenciales en sus secciones públicas. Las normativas pueden consultarse en los siguientes enlaces:

- **Política de Privacidad:** `https://www.linuxquestions.org/privacy.php`
- **Reglas de Registro:** `https://www.linuxquestions.org/questions/register.php`

El sitio declara que las contraseñas son protegidas criptográficamente en sus bases de datos y no pueden ser leídas por los administradores. En cuanto a la política de robustez, el formulario base requiere una longitud mínima, pero no exige obligatoriamente esquemas de alta entropía (combinación estricta de mayúsculas, números y símbolos). Además, no cuenta con un sistema nativo de autenticación multifactor (2FA/MFA) habilitado por defecto para todos los miembros estándar, aunque todo su tráfico en tránsito se encuentra mitigado por cifrado HTTPS/TLS.

2.7. Demuestra 4 conclusiones sobre la seguridad

A partir de las auditorías realizadas, se pueden destacar las siguientes 4 conclusiones técnicas sobre la seguridad de esta implementación:

1. **El hash en el cliente actúa como contraseña en texto plano:** Delegar el cálculo del hash MD5 al navegador no aporta confidencialidad frente al servidor. Dado que el backend valida este exacto valor para otorgar la sesión, cualquier atacante que intercepte el parámetro podrá reutilizarlo directamente para vulnerar la cuenta sin necesidad de conocer la contraseña original.

2. **Uso de un algoritmo criptográfico obsoleto:** El protocolo MD5 se considera obsoleto debido a su alta propensión a colisiones y a la extrema velocidad con la que puede ser computado en hardware moderno (como tarjetas gráficas). Un atacante que logre extraer un hash de esta naturaleza puede recurrir al uso de diccionarios o tablas arcoíris (*rainbow tables*) y descubrir su valor original en fracciones de segundo.

3. **Ausencia de esquema Desafío-Respuesta (Challenge-Response):** La arquitectura analizada no incorpora una sal (*salt*) dinámica ni un *nonce* otorgado por el servidor para cada intento de inicio de sesión. Al enviar repetitivamente un valor estático idéntico, el sistema se mantiene vulnerable a ataques de repetición (*replay attacks*) a nivel de la capa de aplicación.

4. **Desviación de los estándares modernos de seguridad:** En contraposición con las buenas prácticas recomendadas internacionalmente por organismos como OWASP o NIST, el flujo examinado asume erróneamente funciones de seguridad críticas en el frontend. El enfoque correcto exige transmitir el texto plano a través del canal seguro TLS y delegar por completo en el backend el procesamiento computacional de algoritmos robustos y lentos (tales como Argon2id, bcrypt o PBKDF2), aplicando una sal única por cada usuario registrado.